RAILcom

Information Security Management System

A Proposal to the CEO & Senior Management Team

Module: UFCFRB-15-3 | Security Management in Practice

Group 5 · UWE Bristol · Academic Year 2025–2026

ISO/IEC 27001:2022

Presentation Structure — Three Assessment Questions

Intro	**Case Study Overview** Who is RAILcom? What went wrong? Key people & the breach.
Q1	**Why Does RAILcom Need an ISMS and ISO 27001:2022 Framework ?** Business case, risk landscape, what an ISMS is and why it is essential here.
Q2	**Threat Assessment and Controls to mitigate them.** ISO 27001:2022 — Risk and controls identified for People/Process/Technology.
Q3	**Legal, Regulatory & Implementation challenges** UK GDPR, PCI DSS v4.0, NIS2 Directive, HIPAA — failures, obligations & phased roadmap.
End	**Conclusion & Recommendations** Critical actions for the Board to approve today.

Case Study Overview — RAILcom: A Railway Disaster?

THE SETTING

RAILcom is a railway operator undergoing digital transformation — "Railcom 2.0" — to modernise ticketing, scheduling and customer management. They plan to launch ComCard (a prepaid multi-transit smart card) and plan to take it online.

The push for speed-to-market caused the CEO (James) to defer cybersecurity investment. The CIO (Alice) repeatedly warned about three overlapping weaknesses:

"People, processes, and technology — we need to fix all aspects of the problem. When a good system encounters a bad culture, the bad culture wins."

Within this environment, an insider attacker named Kira exploited every gap Alice had identified.

KEY ROLES

James — CEO

James is responsible for leading the “Railcom 2.0” and overall strategy of the Railcom. He dismissed cyber risk, set complacent culture.

Hank — CFO

Responsible for overseeing financial operations, allocating budget.

Alice — CIO

Plays a pivotal role in managing IT infrastructure, overseeing projects, cybersecurity and fostering innovation.

Lev — IT Dir.

Manages technology resources and employees to ensure that IT operations run smoothly.

Kira — Employee

RAILcom employee who had uncheked privilege along with many others.

The Attack —Twin-Flank Strategy

FLANK 1 — Domain Spoofing

railcoms.com registered— a phished ComCard site mimicking Railcom. Sent spoofed emails from ticketsales@railcoms.com impersonating CEO James.

Customers entered payment card details believing the online ComCard had launched. The fake site ran for 30 days undetected.

FLANK 2 — Internal: Keylogger via Phishing

"Railcom 2.0" memo email to payroll staff — employees opened the attachment without suspicion.

A keylogger Trojan spread to multiple terminals via Railcom's uncontrolled file-sharing practices.

Employee passwords and credentials were harvested. Payroll funds were siphoned to external accounts.

WHY IT WORKED —All three corners of the cybersecurity triangle:

TECHNOLOGY

Legacy 1980s systems, unpatched. No EDR, no DMARC/SPF. IDS only around Railcom 2.0 — payroll unprotected. No network segmentation.

PEOPLE

No phishing training. Passwords on sticky notes. Managers didn't enforce clean desk. File-sharing culture spread the malware.

PROCESSES

No IRP, no MFA, no proper processes. "Predict-prevent-detect-respond" policy existed on paper — less than 10% knew about it.

Q1 — Why Does RAILcom Need an ISMS?

Q1

An ISMS is a systematic approach to managing sensitive information across people, processes, and technology — the exact three areas that failed RAILcom.

01

Asset Protection

RAILcom holds customer PII & payment data (ComCard), employee payroll & HR records, and operational timetabling data — each governed by different laws. Without an ISMS there is no single method to classify and protect them.

02

Regulatory Compliance

UK GDPR (Arts.25, 32, 33), PCI DSS v4.0, and NIS2 all require documented, auditable security measures. ISO 27001 is explicitly recognised by the ICO and NIS2 authorities as evidence of "appropriate measures".

03

Business Continuity

The breach hit payroll, customer service, and IT simultaneously. There was no IRP, no escalation path. An ISMS provides formal incident response and recovery — reducing Mean Time to Detect and Respond.

04

Stakeholder Confidence

ISO 27001 certification is third-party verified proof of security maturity — critical for a public transport operator.

05

Return on Investment

ICO fines alone reach £17.5M. IBM Security (2023): mature ISMS organisations contain breaches 54 days faster and save $1.49M per incident on average. ISMS cost is a fraction of the breach cost.

"You can't only protect one corner of the triangle and leave the other two vulnerable — the triangle will crumble."

— Alice (CIO), RAILcom Case Study

Q1 — Framework Selection: ISO 27001:2022

Q1

PRIMARY FRAMEWORK — ISO/IEC 27001:2022

- ONLY internationally certifiable ISMS standard
- 93 controls across 11 domains (Annex A)
- Built on the PDCA cycle — ongoing improvement
- ICO explicitly recognises it as evidence of "appropriate measures" under UK GDPR Art.32
- NIS2 Art.21 competent authorities accept ISO 27001 as a compliant risk management framework
- Directly addresses RAILcom's root failures: culture, management commitment, human-centred controls

Q2 — Risk Assessment: 12 Identified Risks (ISO/IEC 27005:2022)

Q2

Risk Score = Likelihood (1–5) x Impact (1–5) | CRITICAL 20–25 HIGH 13–19 MEDIUM 7–12 LOW 1–6

ID	Risk (from Case Study)	L	I	Score	Level	Cat.	Treatment (ISO 27001 Annex A)
R-01	Potential endpoint compromise (Keylogger Trojan via phishing email / Domain spoofing)	4	5	20	CRITICAL	P/T	A.8.7, A.6.3, A.8.23
R-02	Unauthorized access or misuse of internal resources.	3	5	15	HIGH	P/Pr	A.6.1, A.5.3, A.5.18
R-03	Malicious softwares affecting core systems (eg Ransomware)	4	5	20	CRITICAL	T/Pr	A.8.20, A.8.22, A.8.13
R-04	External digital impersonation (fake domain like comcard)	4	4	16	HIGH	T/Pr	A.8.23, A.5.26, A.6.3
R-05	Inadequate authentication practices (Weak passwords / no MFA/ passwords on sticky notes)	5	4	20	CRITICAL	P/Pr	A.8.5, A.5.17, A.7.7
R-06	Privileges distribution without proper oversight.	4	4	16	HIGH	Pr	A.5.3, A.8.2, A.5.18
R-07	Unnpatched and unmonitored systems.	4	4	16	HIGH	T	A.8.8, A.8.19, A.8.31
R-08	Lack of structured response to incidents (No IRP)	3	5	15	HIGH	Pr	A.5.24, A.5.25, A.5.26
R-09	Exposure of sensitive customer information (eg customer names, comcard information)	4	5	20	CRITICAL	T/Pr	A.8.24, A.8.20, A.8.25
R-10	USB / BYOD — no MDM, no acceptable-use policy	4	3	12	MEDIUM	P/T	A.6.7, A.7.7, A.8.12
R-11	Uncontrolled file-sharing spread Trojan to 7 terminals	4	4	16	HIGH	T/Pr	A.8.7, A.8.20, A.8.22
R-12	No cybersecurity training — CEO complacency (root cause)	5	4	20	CRITICAL	P	A.6.3, A.5.4, A.5.1

Q2 — Security Controls: People · Process · Technology

Q2

TECHNOLOGY

Multi-Factor Authentication (A.8.5)
TOTP/push MFA for all users; YubiKey hardware tokens for finance & IT. Directly addresses Kira's credential theft — passwords on sticky notes stop being the only barrier.

Endpoint Detection & Response (A.8.7)
EDR (CrowdStrike/SentinelOne) replaces outdated antivirus — catches keyloggers in real-time. Addresses R-01 keylogger Trojan confirmed in case study.

Network Micro-Segmentation (A.8.20/22)

Separate VLANs: payroll, ComCard CDE, CRM & corporate LAN. Stops lateral spread — addresses Alice's NHS ransomware warning.

DMARC / DKIM / SPF (A.8.23)

Blocks CEO spoofing emails (ticketsales@railcoms.com). Google (2023): 99%+ reduction in spoofed messages.

P2PE & Tokenisation (A.8.24)

TLS 1.3 on payment pages; AES-256 at rest; ComCard data tokenised. PCI DSS Req.3 compliance.

PEOPLE

Security Awareness Training (A.6.3)
Annual gamified programme + monthly phishing simulations. Proofpoint (2023): 86% reduction in click-rates. CEO must visibly champion it — the root cause per case study.

Clean Desk & BYOD Policy (A.7.7/A.6.7)

Enforced no-sticky-note policy; MDM (Microsoft Intune) on all personal devices used for work. Addresses confirmed BYOD risk.

Pre-Employment Vetting (A.6.1)

Background checks for all roles with sensitive access; annual re-vetting of IT & finance staff. Kira exploited the absence of this.

CISO Board Reporting

CISO reports quarterly breach intelligence; cybersecurity KPIs in senior manager reviews. Changes the culture James failed to set.

PROCESS

Separation of Duties & RBAC (A.5.3/A.8.2)

Payroll team only accesses payroll; developers cannot reach production. Removes the cross-access that Lev noted: "a few hops to ticketing."

Incident Response Plan (A.5.24/5.26)

IRP based on NIST SP 800-61r2: escalation matrix, 72-hr ICO notification, evidence chain. Addresses the "tattered raft" Alice found herself on.

Joiner-Mover-Leaver Process (A.5.18)

Auto-deprovisioning within 24 hrs of any role change or exit. Closes intern access gaps confirmed in case study.

DPIA Before New Products (A.8.25)

Mandatory Data Protection Impact Assessment before ComCard goes online — required by GDPR Art.25 and absent at launch.

Q3 — Legal & Regulatory Compliance: Confirmed Violat

Q3

RAILcom is currently NON-COMPLIANT with all three primary regulatory frameworks. Aggregate fine exposure: up to £17.5M under UK GDPR alone.

UK GDPR

UK Government retained GDPR via Data Protection Act 2018

- Art.32: No encryption, no MFA, no security policy documented
- Art.33: Fake site ran 30 days — no 72-hr ICO breach notification made
- Art.25: ComCard outsourced with no DPIA, no Privacy by Design

ISMS Response:

IRP triggers 72-hr ICO notification | DPIA mandatory gate for all new products | ISO 27001 Annex A.8.5, A.8.24, A.5.24 provide "appropriate measures"

Up to £17.5M or 4% global annual turnover (ICO, 2023)

PCI DSS v4.0

Mandatory for all entities handling ComCard payment data

- Req.1: No CDE boundary defined; payroll and ticketing interconnected
- Req.3: No encryption or tokenisation of cardholder data
- Req.8: No MFA — single-factor access across entire organisation

ISMS Response:

VLAN isolates CDE | TLS 1.3 + tokenisation meets Req.3 | MFA deployment within 30 days | Annual ASV scans and QSA audit pre-ComCard launch

Card brand fines + loss of payment processing capability (PCI SSC, 2022)

NIS2 Directive

RAILcom is an Essential Entity under Annex I — strictest obligations

- Art.21: No risk management framework, no BCP, no supply chain controls
- Art.23: No 24-hr early warning or 72-hr full report to ORR capability
- Art.32: James (CEO) is personally liable — management accountability

ISMS Response:

ISO 27001 certification satisfies Art.21 | IRP provides 24/72-hr ORR pathway | CISO board reporting directly addresses management accountability

ORR improvement notices + financial penalties + personal liability for James

Q3 — ISMS Implementation Roadmap (PDCA Model)

Q3

Barriers identified in the case study: executive complacency (James), budget misframing (Hank), legacy complexity, and absence of cyber governance. The roadmap addresses each.

Phase 0
IMMEDIATE

Time: 0–30 Days

- Appoint board-level CISO & Data Protection Officer
- Register with ORR as NIS2 Essential Entity
- Preserve all forensic evidence (logs, email headers) for police
- Draft initial IRP and staff breach communication

Phase 1
CRITICAL

Time: 30–90 Days

- Deploy MFA for ALL user accounts — top priority
- Publish IRP and conduct first tabletop exercise
- VLAN segmentation: isolate payroll and ComCard CDE first
- Enforce RBAC and begin JML access deprovisioning
- Launch monthly phishing simulation programme

Phase 2
HIGH PRIORITY

Time: 3–6 Months

- EDR on all endpoints + DMARC/DKIM/SPF enforcement
- PCI DSS gap analysis + DPIA for ComCard online launch
- First bi-annual penetration tests and vulnerability scans
- Clean desk policy enforced + BYOD MDM rollout (Intune)
- Pre-employment vetting programme operational

Phase 3
SUSTAIN

Time: 6–18 Months

- Legacy payroll migration to SaaS (highest-criticality asset)
- UEBA deployed for insider threat detection (post-Kira)
- Supply chain security assessments for all vendors
- ISO 27001 Stage 1 (documentation) audit by certifier
- Board tabletop exercises + cybersecurity KPI reviews

Conclusion & Recommendations

"The damage to Railcom was more than money — it was trust. The breach was not a shock; it was the direct result of governance failures Alice had repeatedly diagnosed."

Q1

The Breach Was Preventable

4 Critical + 6 High risks — all from documented people/process/technology failures. CEO complacency (James) was the root cause multiplier. An ISMS would have prevented every single risk identified.

Q2

Framework & Controls Are Clear

ISO 27001:2022. Start immediately: MFA within 30 days, IRP within 30 days, VLAN segmentation within 90 days. These are low-cost, high-impact actions requiring board authorisation today.

Q3

Regulatory Exposure Is Real & Urgent

UK GDPR, PCI DSS v4.0, and NIS2 are all confirmed violations. ICO fines alone reach £17.5M. James faces personal liability under NIS2 Art.32. The ISMS is not optional — it is the legal minimum.

References

1. Ahmad, A., Bosua, R. and Scheepers, R. (2014) 'Protecting organisational competitive advantage: A knowledge leakage perspective', Computers & Security, 42, pp. 27-39. https://doi.org/10.1016/j.cose.2014.01.001

2. Beckers, K. (2015) Pattern and Security Requirements: Engineering-Based Establishment of Security Standards. Cham: Springer.

3. Bulgurcu, B., Cavusoglu, H. and Benbasat, I. (2010) 'Information security policy compliance: An empirical study of rationality-based beliefs and information security awareness', MIS Quarterly, 34(3), pp. 523-548. https://doi.org/10.2307/25750690

4. CERT (2023) Common Sense Guide to Mitigating Insider Threats. 7th edn. Carnegie Mellon University Software Engineering Institute. Available at: https://www.cert.org/insider-threat/ (Accessed: 12 April 2026).

5. Disterer, G. (2013) 'ISO/IEC 27000, 27001 and 27002 for information security management', Journal of Information Security, 4(2), pp. 92-100. https://doi.org/10.4236/jis.2013.42011

6. European Parliament (2022) Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2 Directive). Official Journal of the European Union. Available at: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32022L2555 (Accessed: 10 April 2026).

7. Gordon, L.A. and Loeb, M.P. (2002) 'The economics of information security investment', ACM Transactions on Information and System Security, 5(4), pp. 438-457. https://doi.org/10.1145/581271.581274